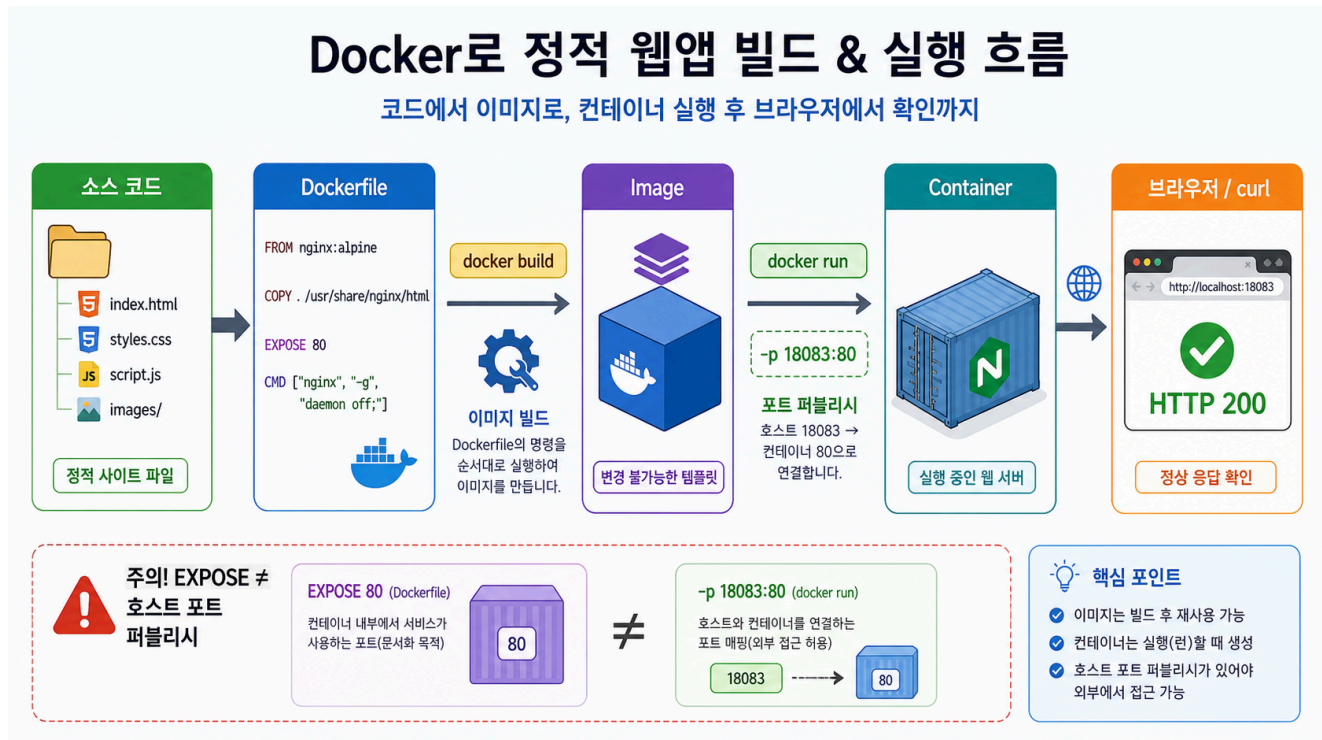


4교시: Build/run/verify/scan - 안전한 image 후보 만들기



수업 목표

- docker build가 image artifact를 만드는 과정임을 설명한다.
- docker run이 image에서 container process를 시작하는 과정임을 설명한다.
- curl로 사용자 관점의 정상 기준을 확인한다.
- docker scout cves로 기본 취약점 점검을 수행하고 안전한 image 후보 기준을 만든다.

개념 설명

build, run, verify, scan은 서로 다른 단계다. docker build는 image를 만든다. 이 단계가 성공했다는 것은 Dockerfile과 context로 image artifact를 만들었다는 뜻이지, 서비스가 정상이라는 뜻도 아니고 안전하다는 뜻도 아니다.

docker run은 image를 container로 실행한다. container가 Up이어도 애플리케이션이 사용 가능한지는 별도 문제다. curl 또는 browser 확인을 해야 host에서 접근 가능한지, HTTP 응답이 정상인지 알 수 있다.

여기에 보안 관점의 한 단계가 더 필요하다. image는 base OS와 package를 포함한다. 따라서 정적 HTML 앱이라도 base image 안의 OS package 취약점이 있을 수 있다. docker scout cves는 image

같은 software artifact의 CVE를 분석하는 Docker CLI 명령이다. 수업에서는 이 명령을 사용해 image를 배포해도 되는지, 보류해야 하는지, 예외 기록이 필요한지 판단하는 첫 gate로 사용한다.

Lab 사용법

이 교시는 week2/day3/labs/static-site/README.md의 **Build**, **Run**, **Verify**, **Security Scan** 섹션을 따라간다. 강사는 명령 전에 expected pattern을 먼저 보여주고, 실행 후 실제 출력이 어느 줄과 대응되는지 확인한다.

실습 명령

```
cd week2/day3/labs/static-site
docker build -t paperclip-static-site:day3 .
docker images paperclip-static-site
docker run -d --name paperclip-day3-static -p 18083:80 paperclip-static-site:day3
```

검증 명령과 기대 결과

```
docker ps --filter name=paperclip-day3-static
curl -I http://localhost:18083
curl -s http://localhost:18083 | grep "Day 3 Static App"
```

Expected pattern:

```
STATUS Up
0.0.0.0:18083->80/tcp
HTTP/1.1 200 OK
<h1>Day 3 Static App</h1>
```

취약점 점검

먼저 Scout 사용 가능 여부를 확인한다.

```
docker scout version || true
```

가능하면 image CVE를 확인한다.

```
docker scout cves paperclip-static-site:day3 || true
docker scout cves --only-severity critical,high paperclip-static-site:day3 ||
```

```
true
```

Expected interpretation:

Scout가 실행되면 CVE summary, package, severity를 확인한다.

critical/high가 있으면 base image 변경, package update, 예외 사유 기록 중 하나를 판단한다.

Scout가 설치되어 있지 않거나 로그인이 필요하면 그 사실을 scan blocker로 기록한다.

안전한 image 후보 기준

단계	성공 증거	실패하면 먼저 볼 곳
build	paperclip-static-site:day3 image 생성	Dockerfile, build context
run	container status가 Up	image tag, container name, logs
verify	HTTP/1.1 200 OK와 HTML 문구	-p host:container, app port
scan	critical/high CVE 없음 또는 조치/예외 기록 있음	base image tag, Scout output, package list
handoff	실행 명령, 확인 URL, scan 결과가 README에 남음	lab README 누락

학생이 말할 수 있어야 하는 문장

Build 성공은 실행 가능성의 시작일 뿐이다.

Run/verify로 서비스 정상 여부를 확인하고, scan으로 image 보안 위험을 확인한다.

취약점이 나오면 무조건 실패라고 외우는 것이 아니라 severity, fix 가능성, base image 대안, 예외 사유를 판단한다.

Scout가 실행되지 않는 환경이면 미수행 사유를 남기는 것도 운영 기록이다.

핵심 포인트

Day 3의 S4 완료 기준은 이미지가 빌드되고 HTTP 200이 나온다가 아니다. 최소 기준은 build/run/verify/scan evidence를 남긴 안전한 image 후보를 만드는 것이다.

다음 연결

다음 교시는 만들어진 image의 layer/cache/size evidence를 확인해 rebuild 비용과 base image 선택 영향을 본다.